

ZK Full Stack Threat Model Document

Created: 25 August 2026

Last Updated: 02 September 2026

[App Description](#)

[Data-flow](#)

[Data](#)

[Threats](#)

[STRIDE](#)

[Risk Rating](#)

[Results](#)

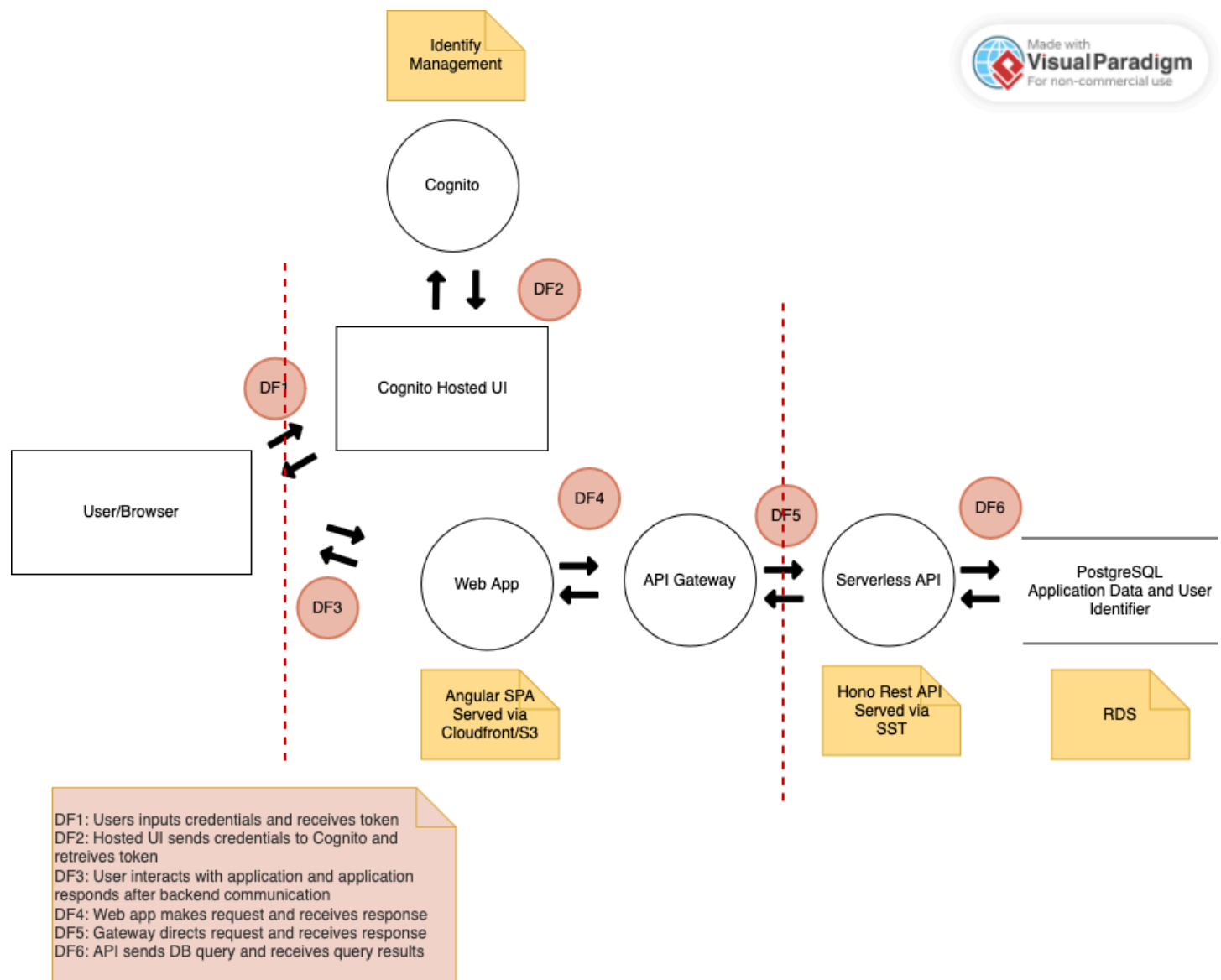
App Description

This application allows users to work on accounts to create notes and link them to sources. Additional features include a node graph, which displays connections between notes and sources, and a tagging system. The point of the application is to supply a minimalist Zettelkasten note-taking system for users. This application was built for the web and will be ported to Android for easy mobile usage.

A typical happy path for a user might include:

1. A user logs in or opens the app if already logged in.
2. A user adds a note with a name and note content and adds the source, such as a YouTube video link, a book citation, or a friend's name. They may optionally tag the note into a category, such as "Baking" or "Astrophysics".
3. The user reviews their notes via the list view or the graph view to make connections and apply them to their own work and research.
4. The user typically will stay logged in for quick note-taking.

Data-flow



Data

Data	Confidentiality Threat	Integrity Threat	Availability Threat
Cognito Data (sub [user identifier], email, email_verified, account state information, password hash This data is managed by AWS, not us!	Critical	Critical	Critical
Cognito Tokens: ID, Access, Refresh Questions: What can access these tokens and where are they saved?	ID: High, Others: Critical	ID: High, Others: Critical	High
Note Data: name, content, related dates This data is necessary for the application to function, but should be recoverable.	Medium	High	High
Source Data: title, artifact, dates This data is necessary for the application to function, but should be recoverable.	Medium	High	High
App-based user data: user Cognito sub (user identifier) This data is necessary for the application to function, but should be recoverable.	High	High	High

Threats

Overall, the intended user is someone keeping notes and tying those notes to sources. An unintended user is likely someone trying to get access to others' notes or to disrupt others' notes. The intended usage is for tying notes to sources, but theoretically, the system could be used for anything that is represented with links and descriptions.

STRIDE

This is not a comprehensive STRIDE evaluation, but it should represent a good example of my style.

Data Flow / Component / Boundary	STRIDE Category	Risk	Possible Solutions
Browser <-> Cognito <-> SPA	Spoofing	Token Theft via XSS: The Cognito JWT used in DF1-DF3 is stored in local storage by default	The token can be saved to session storage instead, so that it's wiped out when the browser is closed. Or, even better, refactor the auth flow from the FE->BE so that the app utilizes cookie storage instead and the data can utilize the HttpOnly attribute so that scripts running in the browser cannot access it.
Browser <-> Cognito <-> SPA	Tampering	Redirect / Callback URL Manipulation: Callback and Logout URLs used in DF1-DF3 are configured in the AWS console for Cognito and may be for local development or use a wildcard.	Ensure that the URLs are set up in Cognito to be exact so that users can't be redirected unexpectedly
SPA <-> Gateway <-> API/DB	Elevation of Privilege	Broken/Incomplete Authorization: In DF4-DF6, the API may not be configured to check that the JWT is authenticated as well as authorized based on which user is accessing which data	Ensure that the application is checking that the JWT is not only valid but also belongs to the right user.
SPA <-> Gateway <-> API/DB	Denial of Service	Serverless Cost Exhaustion: Because of the low cost requirements of this project, a flood of attacks on the gateway/API will quickly	Rate-limit requests or throttle the gateway. Set thresholds on the serverless AWS system.

		deplete the available requests.	
API <-> DB	Information Disclosure	SQLi: Requests to the API (through frontend or otherwise, based on settings in the Gateway) may pass through raw SQL. This refers to DF5/DF6.	Use prepared statements or parameterized queries. The selected tool (Drizzle) should already supply this. Disable multiple statements per query.
API <-> DB	Repudiation	Lack of Auditing: We can't be prepared for everything. If something does happen, not knowing who is making requests/updates would stall investigations.	Set up logging to capture times, user IDs, actions, affected records, etc for updates.
DB	Elevation of Privilege & Information Disclosure	Accessible Database: RDS default configuration may be open, or the database may be publicly available.	The instance should be in a private subnet and restrict inbound traffic to only the security group that matches the API.

Risk Rating

This is not a comprehensive Risk evaluation, but it should represent a good example of my style.

Flow	Threat Description	Likelihood	Impact	Final Risk Score
DF1-DF3	Token Theft via XSS: The Cognito JWT is stored in local storage by default.	Medium	High	High
DF1-DF3	Redirect / Callback URL Manipulation: Callback and Logout URLs are configured in the AWS console for Cognito and may be for local development or use a wildcard.	Low	High	Medium
DF4-DF6	Broken/Incomplete Authorization: The API may not be configured to check that the JWT is authenticated as well as authorized based on which user is accessing which data	High	High	High
DF4-DF6	Serverless Cost Exhaustion: Because of the low cost requirements of this project, a flood of attacks on the gateway/API will quickly deplete the available requests.	High	Low	Medium

DF5/DF6	SQLi: Requests to the API (through frontend or otherwise, based on settings in the Gateway) may pass through raw SQL.	Medium	High	High
DF6	Lack of Auditing: We can't be prepared for everything. If something does happen, not knowing who is making requests/updates would stall investigations.	Medium	Medium	Medium
DF6	Accessible Database: RDS default configuration may be open, or the database may be publicly available.	Medium	Critical	Critical

Results

This section will remain incomplete until related tickets are completed. Updates will be added to this section as work is completed.